

Инъекция внешних сущностей XML

Описание проблемы

Инъекция внешних сущностей XML (также известная как XXE) — это уязвимость веб-безопасности, которая позволяет злоумышленнику вмешиваться в обработку XML-данных приложением.

- Атакующий передает приложению специально сформированные данные: это может быть XML-запрос или XML-документ.
- Этот запрос никак не валидируется и в итоге либо вызывает ошибку, либо попадает в базу данных.
- База данных пытается обработать этот запрос. В этот момент есть вероятность DOS-атаки, например, если в запросе есть цикл.
- Если целью атаки был не DOS, то сервер обрабатывает запрос, в результате которого злоумышленник может добавить свою информацию на сервер или получить данные организации.

Внедрение сущностей в XML происходит через элементы DOCTYPE и ENTITY.

Пример небезопасного кода

Представим, что этот код формирует произвольный xml-запрос из пользовательского ввода с использованием библиотеки lxml.

```
from lxml import etree
parser = etree.XMLParser(resolve_entities=True) # ОПАСНО
root = etree.fromstring(user_xml, parser=parser)
print(etree.tostring(root, pretty_print=True, encoding="unicode"))
```



Библиотека lxml до версии 6.1.0 уязвима к XXE даже без явного указания `resolve_entities=True`

Пэйлоад ниже определяет внешнюю сущность `xxe`, значение которой - содержимое файла `/etc/passwd`. Эта сущность затем используется в элементе `productId`.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck><productId>&xxe;</productId></stockCheck>
```

В итоге приложение обработает запрос и включит в ответ содержимое `/etc/passwd`.

```
Invalid product ID: root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
```

XML-инъекция

XML-инъекция представляет собой тип атаки на приложение, связанный с некорректной обработкой файлов формата xml. Атака заключается в нарушении логики работы приложения с целью выполнения произвольных конструкций кода. Кроме того, XML-инъекция может быть применена для организации атак типа отказ в обслуживании (xml-бомбы).

При использовании парсера от библиотеки xml, lxml и некоторых [других](#) есть возможность провести атаку.

Подверженными уязвимости считаются следующие компоненты:

- xml.etree.ElementTree;
- xml.etree.cElementTree;
- xml.dom.expatbuilder;
- xml.sax.expatreader;
- xml.dom.minidom;

- xml.dom.pulldom;
- xml.sax;
- lxml.etree;
- xmlrpclib;
- xmlrpc.client.

Исключение составляют безопасные методы:

- Element;
- SubElement;
- toString.

Последствия эксплуатации

Внедрение внешних сущностей XML часто позволяет злоумышленнику просматривать файлы в файловой системе сервера приложений и взаимодействовать с любыми серверными или внешними системами, к которым может получить доступ само приложение.

Как исправить?

Для обработки XML используйте библиотеку [defusedxml](#).

Для фильтрации входных параметров:

Белый список. Если необходимо поддерживать обработку XML, то нужно создать «белый список» допустимых сущностей, которыми ограничиться парсер.

Если белые списки использовать невозможно, то необходимо хотя бы фильтровать специальные символы <, ", >, и &.

Дополнительно

1. Своевременное обновление и применение патчей. Постоянно следите за обновлениями вашего XML-парсера и других компонентов системы, которые могут быть уязвимыми к ХХЕ-атакам.
2. Отключение DTDs и внешних схем, если они не требуются для работы приложения.